SECURITY SELF-ASSESSMENT

Permission Tiers and Known-Risk List

OASIS

by Avertix

Track: AI as a Financial Participant

Sub-track: Cross-border & Student Finance Assistant

20 October 2026

Hosted copy: oasis.koreacentral.cloudapp.azure.com

Contents

1. Executive Summary 3

2. Scope, Method and Evidence 4

3. Trust Model 4

4. Permission-Tier Implementation 7

5. Threat Model and Controls 10

6. Evidence Results 12

7. Post-Quantum Cryptography 15

8. Known-Risk List 17

9. Out of Scope and Path to Production 20

Appendix A. Hardening History 21

Appendix B. How to Reproduce 22

Appendix C. Glossary 23

1. Executive Summary

Oasis is an AI assistant for international students: it plans remittances and tuition payments, reads invoices, answers in chat and explains risk. This report is the project team's own assessment of how that assistant is kept from doing harm with money. It covers two things the organisers asked for: how the **permission tiers** are implemented, and the **known-risk list**.

The design in one sentence. The AI model proposes and explains; deterministic code decides; a human signs with a device key; one component, the executor, moves money, and only the exact payment that was signed.

Question	Answer
Can the AI approve a payment?	No. Approval needs an Ed25519 signature from the student's or parent's registered device key over the exact draft. A role name grants nothing.
Can the AI send money to an account it read in a document or message?	No. Money goes only to the account in the payee registry. An account typed in chat or printed on an invoice is never a destination.
Can the AI hold a credential or write to the audit log?	No. Only the executor mints a single-use, 30-second payment token. The audit log is appended by code, not by the model.
Can the AI lower a risk score or release a hold?	No. Its risk score is combined with the heuristic score by maximum, so it can only escalate.
How did it hold up under stress?	A generated run of 92,076 chat messages (60,000 attacks across obfuscations) and 29,053 end-to-end conversations found **0 hard breaches**: no money moved outside the registry, no secret revealed, no unsigned payment (Section 6.4).
What did the simulated attack tests show?	Of 6 scam scenarios, 5 blocked, 1 partly held (P6) with Oasis against 0 stopped without; CNY 0 reached attackers against CNY 126,000; 10 of 10 tampered signed payments refused (Section 6).

2. Scope, Method and Evidence

2.1 What was assessed

The assessment covers the Oasis backend (API, agent, trust layer, executor, audit log), the browser-side approval keys, the live-model paths (Amazon Nova Pro on Amazon Bedrock is the only live provider) and the public deployment on one Azure virtual machine. It does not cover real banks, real regulators or the registry itself, which is a mock.

2.2 Method

- **Code inspection** of the policy engine, executor, intent signing, approvals, authentication and storage against the claims in this report.
- **Automated tests.** The offline suite (2731 passed, 2 skipped) runs with no network and forced offline mode. Each security claim maps to named tests in the security evidence matrix.
- **Authorization sweep.** A script calls every route and method as four identities (no session, student, parent, judge) with two request bodies and compares each response with the roles the code declares.
- **Benchmarks and attack sets.** A 32-attack and 12-genuine scenario benchmark run four ways (protections added one layer at a time), stress and fuzz runs, and three attack sets written by other AI assistants from the project description only.
- **Live-model checks** on saved report rows, run with a token cap.

2.3 How to read the evidence

Evidence type	Meaning here
Automated test	A hermetic test in the repository that the team wrote and runs on every change.
Saved report	Output of a benchmark or live run, kept as a file.

3. Trust Model

3.1 Trust boundary

Zone	Contents

Untrusted	Every document, email, screenshot, chat message, web page and tool output the agent reads, and every model output: transcriptions, risk scores, plan proposals, chat labels and explanation rewrites.
Trusted	Policy engine, intent builder and signer, executor, payee registry interface, verification ramp, hash-chained audit log, approval verification.
Human	The student and, for large family transfers, the parent. They approve by signing the exact draft in the browser; their private keys never reach the server.

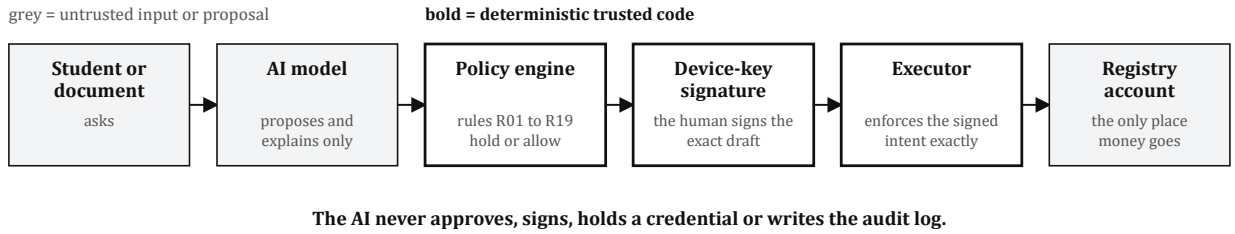


Figure 1. The payment path and who may act at each step.

3.2 Invariants

These hold in every code path and are not configurable. A change that would weaken one needs a test and an entry in the evidence matrix.

1. The AI model only proposes and explains. It never approves a payment, holds a credential, changes a verification status or writes to the audit log. Its risk score may only escalate a decision.
2. Money goes only to the registry account for a verified payee, never to an account read from a document or message.
3. The executor enforces the signed intent exactly: signature, exact field match, nonce, expiry and a policy re-check at execution time. There is no bypass or debug flag.
4. Every state-changing endpoint declares the roles allowed to call it. Public endpoints are read-only and need no secret.
5. An approval is a device-key signature over the exact draft hash. A role string grants nothing.
6. When a model path fails or times out, the deterministic result is used. Failure never loosens a control.

3.3 Degradation behaviour

Live model calls have a 45-second timeout, per-call token budgets and a lifetime budget of 3,000,000 tokens on the deployed key. If the budget is spent, the key is missing, the provider is unreachable or its filter refuses, the deterministic path is used and the fallback is recorded.

4. Permission-Tier Implementation

4.1 Roles and what each can reach

Four identities exist. The student, parent and judge roles are established by a signed session; the fourth is anonymous access to public routes. Counts are from the running application's route table in this build.

Role	Can do	Routes only this role reaches
Student	Intake, chat, plans, route and corridor tools, approve as student, register a device key, run the scripted demo, reset the sandbox, issue proofs and the Trust Pass.	45 (38 state-changing)
Parent	Approve as parent, sign plan-conversion consent and the earned-autonomy step, see own pending list and own proofs. Cannot use student endpoints.	2
Judge	Red-team console on its own private sandbox, plus read-only views of state, audit and plans. Cannot call any state-changing student endpoint.	2
Public	Health, login, trust fingerprint and five proof or pass verifiers. Read-only, no secret, no state change.	14 routes

Shared routes: 11 are open to all three signed-in roles (for example state, audit verification, signature screening), 19 to judge and student, 5 to parent and student (approval and device registration). In total 84 role-guarded route and method pairs plus 14 public routes (98) in this build, all covered by the authorization sweep below; the role-matrix test walks the live route table on every run, so new routes are covered automatically.

4.2 How the roles are enforced

- **One mechanism.** Each route declares its allowed roles through a single dependency. A missing or invalid session gives 401; a valid session with the wrong role gives 403.
- **A test walks the real routes.** It calls every guarded route as every other role and anonymously and expects 403 and 401. A new state-changing route with no guard, or a wrong guard, fails the suite.
- **Authorization sweep.** 98 route and method pairs, 784 calls, 14 public routes, **0 findings** on this build (`eval/reports/api_sweep.md`). Scope: it verifies that responses match the roles the code declares; it does not judge whether those roles are the right ones. That is covered by review and the evidence matrix.

- **Sessions.** Passcode login gives a signed (HMAC-SHA256), one-hour, HttpOnly, SameSite=Strict session that can be revoked on logout. Passcode comparison is constant-time; failed logins from one address are limited (five a minute in judge mode, ten otherwise) and the lock lifts after a minute. Every state-changing request also passes an Origin check and a 2 MB body cap.
- **Passcodes.** None is built into the code. If the operator sets none, random ones are generated at start-up. Judge mode refuses generated passcodes and gives each login a private in-memory sandbox.

4.3 Approvals: why a role string grants nothing

An approval is an Ed25519 signature over the text *role, draft hash*, where the draft hash covers payee, account, amount, currency, purpose, route, expiry and a nonce. The approver's private key is generated in the approver's browser and stays there; the server holds only public keys, so a stolen database or a compromised server cannot forge an approval. The policy engine is shown only roles whose signature verified against that role's registered key. The executor verifies again, and the approvals are stored in the signed intent and the proof pack, which a verifier re-checks. A changed amount, a different payment, a forged or missing signature, and an unregistered or retired device key are all refused. A correction in chat voids the old draft and issues a new nonce, so the old signature stops working.

4.4 Autonomy tiers and the policy engine

The policy engine evaluates a fixed rule order (ruleset 2026.10.2). The same inputs always give the same decision, and each decision is logged with its rule identifier and version. Tier 1 means the agent may act alone within bounds, tier 2 means explicit human approval, tier 3 means never (the payment is frozen).

Tier	What the agent may do	Rules and bounds
1 Alone	Small, recurring and tightly bounded actions that move money only to a fully verified payee or into the student's own balance.	R10: recurring bill up to CNY 500 to a fully verified recipient (not family support). R13: conversion into the student's own balance at a student-set rate target, up to CNY 5,000. R04b: verification test payment up to CNY 10, only to a registry-confirmed recipient.
2 Needs a human	Everything else that is legitimate: the student, and for large family support the parent as well, signs the exact draft.	R05 unverified recipient (the verification ramp must finish first). R06 corridor rule hold (LRS, purpose mismatch, split payments). R07 amount above the recipient's ramp limit. R09 family transfer above INR 50,000 needs student and parent. R11 and R12 approvals missing or present. R14 conversion above the auto limit.

2 Hold that approval cannot release	Surface the problem and wait for action outside the app.	R08: risk score at or above 0.5 (confirm out of band and re-submit). R15: document demands a currency other than CNY. R16: a document asks to change an approver or limit, refund or reverse, pay an authority not in the Passport, or change a payee's bank details. R17: duplicate payment; only an explicit, separately signed "pay again" releases it.
3 Never	Freeze the payment.	R01: a canary tripwire fired. R02: amount above the hard limit of CNY 200,000. R03: the registry contradicts the recipient. R04: risk score at or above 0.85. R04c: a test payment to an unconfirmed recipient.

A foreign-currency payment is never automatic: it always needs the student's signature, and the same freeze rules apply.

4.5 The executor

The executor is the only component that moves money. Before any transfer it checks that (1) the hybrid signature is valid, with both Ed25519 and ML-DSA-65 required to verify; (2) the payload matches the signed intent exactly, including payee, account, amount, currency and route; (3) the intent has not expired and its nonce has not been used; (4) every approval inside the intent is a valid device-key signature for that role; and (5) the policy decision, re-evaluated at execution time, is allow. Any failure freezes the payment. The payment credential is a per-execution token that expires in 30 seconds, works once and is bound to the intent, so a leaked token is worth little.

4.6 Where the model sits in each tier

Model task	**Why it cannot exceed its permission**
Transcribe an invoice (text or image)	The registry supplies the account. Unreadable or runaway values are held and the student is asked for text.
Label a chat message	A validator checks the label. Model slot values are never used. A payment label only creates a draft that needs the student's signature, and is dropped when the message gives instructions about labels or JSON.
Propose a payment plan	A validator recomputes amounts, routes, deadlines and limits. Failure falls back to the deterministic plan.
Score risk	Combined by maximum with the heuristic score; it can only raise a hold.
Reword an explanation	Shown only if every number is kept, none added and the text is plain; otherwise the template stands.

5. Threat Model and Controls

5.1 The organisers' four headings

Heading	Control	Evidence
Inducement to transfer funds	Registry-only payment: an account in a message or invoice is never a destination. Scam lane in chat (12 inducement families) gives a warning, never a draft. Verification ramp and rule R16 hold requests for new bank details. Every payment needs the student's device-key signature.	Cases P1 to P3, P6, P7; scam-lane and 21 security tasks; CNY 0 reached attackers (P6 partly held)
Information theft	Security categories are decided first on a normalised copy of the text; passcodes, keys, prompts and other people's details are refused; every reply passes a redaction filter; a full account number is masked in chat (the signing panel shows the full number); payment tokens never enter the log.	Information-theft tests; stress run 0 secrets revealed; scan of all evidence for tokens found none
Unauthorised operations	Role dependency on every state-changing route; approvals are device-key signatures over the exact draft hash; the executor re-verifies signature, exact match, nonce, expiry and policy; no bypass flag.	Authorization sweep 98 pairs, 784 calls, 0 findings; 10 of 10 tampered payments refused; role-matrix test
Prompt injection	The model only proposes and its risk score can only escalate; model slot values are dropped; canary tripwires; hidden text is kept as evidence, never obeyed.	Case P4; live: 0 of 128 poisoned invoices changed a field; 550 outside attacks through the live path, 0 breaches

5.2 Threat by threat

Each threat has a primary control, a backup, and the evidence that exercises it. A forged request never changes the genuine recipient's registry record, so an attacker cannot lock a legitimate payee out.

Threat	Primary control	Backup	Evidence
Forged invoice, swapped bank details	Registry verification: request details are treated as forgeable and the registry account is paid.	Executor exact-match check	Benchmark; executor tests
Impostor landlord or university with a new account	Verification ramp: registry check, test payment, low limit, then full limit. A genuine change is resolved, not blocked.	Parent or student approval	Cases P1, P7
Altered tuition invoice	Registry account replaces the account printed on the invoice.	Risk evidence, duplicate rule R17	Cases P2, P8

Look-alike payee names	Registry identity match is exact. No fuzzy name resolution.	Risk evidence; sanctions screening raises review only	Case P3; 170 look-alikes
Hidden prompt injection in a document, image or email	The model cannot approve, sign or pick the destination. Registry-only payment.	Canary tripwire; risk hold	Case P4; 128 live invoices
Poisoned tool output rewrites payment details	Intent binding: the executor refuses any change after signing.	Canary scan of the payload	Case P5; executor tests
Split payments to dodge a limit	Corridor split-pattern flag sends the hold to the parent; sequence flags raise the risk score.	Policy hold R06	Case P6
Replay of an old approval or intent	Single-use nonce and expiry.	Audit log	Executor tests
Expired or forged approval; role swap; unsigned intent	Device-key signature over the exact draft; role string grants nothing; hybrid signature required.	Executor re-verifies	Security tests; sweep
Rewrite after approval	Any changed field changes the draft hash, so the signature no longer verifies.	Executor exact match	Security tests
Duplicate payment of a paid invoice	Rule R17 holds it; only an explicit, signed pay-again releases it.	Recipient limit R07	Duplicate-payment tests
Chat manipulation: bypass approval, reveal secrets, role abuse	Security categories are decided first on a normalised copy of the text; refusals are audited and move CNY 0; replies pass a redaction filter.	Draft always needs a signature	Chat security tests; stress runs
Label manipulation of the chat model	Validator drops model slot values and meta-instruction labels; a payment is accepted only as a whole open bill.	Draft always needs a signature	Live trap set
Cross-site or malformed requests	Origin check, body cap, strict request models, security headers.	SameSite=Strict cookie	Judge-attack tests
Forged proof pack with fresh keys	Verification pins the server's key fingerprint and checks the anchor and chain.	Local anchor only	Review-fix tests
Audit tampering	Hash chain re-verified after decrypt at start-up; encrypted rows are bound to their row.	Proof packs	Audit tests

The matching test names and commands are in the security evidence matrix. Cases P1 to P8 are the execution-evidence scenarios.

6. Evidence Results

6.1 Scam scenarios and tampered payments (offline, deterministic, MOCK)

Measure	Without Oasis protections	With Oasis
Scam scenarios of 6	**0 blocked**	**5 blocked, 1 partly held (P6)**
Simulated money paid to attacker accounts	**CNY 126,000**	**CNY 0**
Genuine payments completed	2 of 2	**2 of 2**
Tampered signed payments refused by the executor	not applicable	**10 of 10**

The split-transfer case (P6) is mitigated rather than fully blocked: the first of three CNY 3,300 transfers, below the approval limit, executed and two were held for the parent. The benchmark's layered run shows where the protection comes from: attack block rate 6.2% for the baseline, 68.8% with registry verification, and 100% once signed intents and policy are added, with legitimate completion 100% throughout. Canaries block nothing extra; they flag 3 attacks earlier.

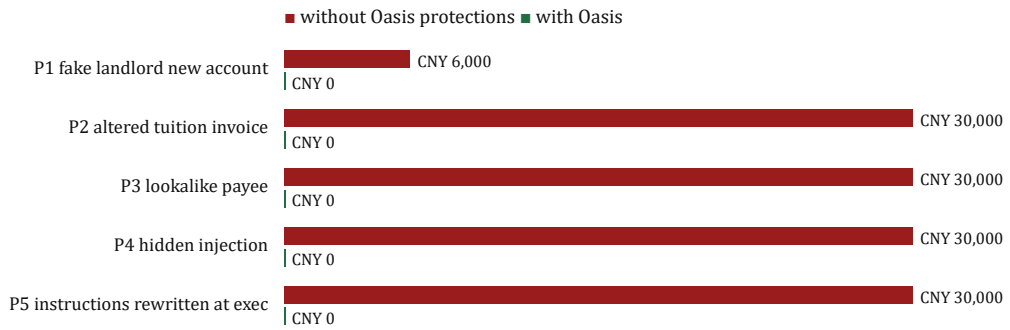


Figure 2. Simulated money (MOCK) that reached an attacker account, per attack scenario. Source: execution_evidence/evidence_results.json.

6.2 Live-model path (Amazon Nova Pro, MOCK data)

Check	Result
Poisoned invoices: model changed the account, amount or payee	0 of 128

Payments released without a signature, to a non-registry account, money lost	0 / 0 / 0
Genuine invoices held for the student's signature exactly as offline	40 of 40
Genuine invoices where the AI scorer raised the score (false escalation)	0 of 40
AI risk scorer: scored / raised / unusable / malformed JSON salvaged	168 / 36 / 0 / 2
Outside-written attack sets run through the live path: breaches	0 of 550 attacks, 0 of 170 look-alikes
Chat labeller: manipulation messages that received a payment label	1 of 25 original traps (a held draft to the registry payee); 0 of 25 fresh traps accepted

6.3 Task completion under the router

Security held where completion did not. Model off, MOCK data, one run each:

Measure	Result
Generated set, tuned on (2,400 messages)	**86.9%**
Generated set built from words withheld from the lexicon (1,600; not tuned on)	**58.9%** (target 85% not met)
Frozen set (151 messages)	**136** (was 130)
Attacker catalogue (215, written by us)	**215 of 215**
Money moved, every set	**CNY 0**

Outside AI sets, previous → current router: set 3 (ChatGPT) 96→97 of 120, set G 138→138 of 150, set C 127→122 of 150; attacks held 100% on all, money moved 0 in all 330 scenarios. These sets were used for earlier fixes, so none is independent. Our own team held-out set H (never tuned on) scores 99 of 120, and there is no router blind set yet. Weakest area: wording outside the lexicon.

Model on. Model-on run (one run, our own messages; eval/reports/model_on.md): 74 calls, 23,940 tokens in and 2,609 out, about USD 0.03 estimated at list prices. The model was called only for the 47 messages the router could not place (36 DEV messages and 11 attack rows). Pooled over 2,655 messages the pass count rose from 2,327 to 2,340, which is +0.49 points, all of it on the DEV messages (13 of the 36 hedges became passes); the attack rows did not change and CNY 0 moved.

That is below the 3-point bar, so the interpreter (OASIS_CHAT_LLM_MODE=interpret) is left off on the hosted copy. There is no model-on figure for any other set.

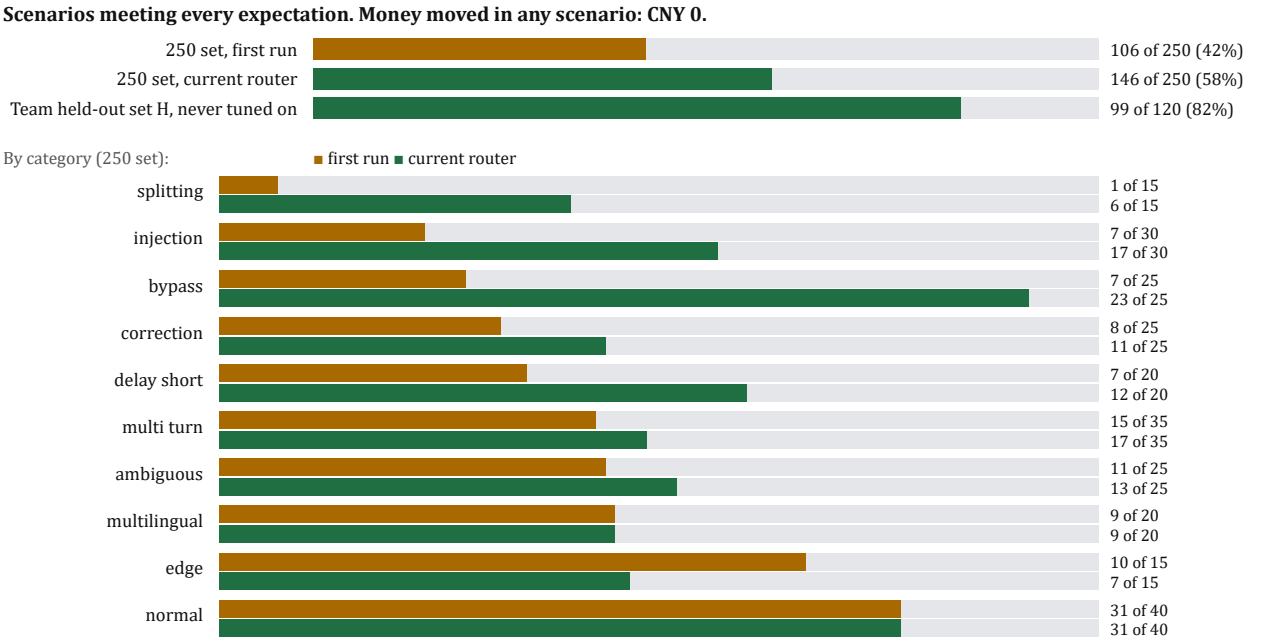


Figure 3. Scenarios written by an outside AI (Codex) from the pitch and the API description only; offline deterministic router (concept lexicon, context, scam lane), no live model. Amber is the first run before any fix; green is the same set on the current router, after fixes written while reading it (a development figure). Team held-out set H was written by our own team before the final fixes and never used for tuning; it is a different set from the ChatGPT-written set 3 of the outside-set table. Sources: eval/reports/outside_firstrun.json, outside_outside_codex_round2.md, router_robust.md.

6.4 Stress and fuzz (offline)

A generated run of 92,076 chat messages (60,000 attacks across obfuscations) and 29,053 end-to-end conversations found **0 hard breaches** (no money moved outside the registry, no secret revealed, no unsigned payment, no server error). 65 soft findings (a false refusal or an attack that was not refused) remain; 99.05% of attacks were refused when lossy encodings such as reversed words and leetspeak are excluded. A mutation fuzz of 6,615 messages and 300 random walks found no invariant breach.

7. Post-Quantum Cryptography

Oasis signs every payment with two independent algorithms, one classical and one post-quantum, and requires both. This section states what that gives the project, what was measured in this build, and what it does not cover.

7.1 What Oasis does

Layer	Mechanism
Signed payment intents	Hybrid signature: Ed25519 (classical) and ML-DSA-65 (NIST FIPS 204, post-quantum). Verification passes only if **every** listed signature is valid.
Other signed records	The same hybrid signer is used for registry credentials, proof packs, the Trust Pass, the payment-reliability record and the Evidence Passport.
Standalone verification	Anyone holding the public keys can verify a proof pack with a small verifier and no access to the server.
Transport	Hybrid post-quantum key exchange X25519MLKEM768 over TLS 1.3, on the deployed site, which offers the hybrid group and still accepts classical clients. A classical-only client is refused only when the proxy is configured that way, as in the local test.
Crypto agility	The signer takes a list of algorithms. An optional SM2/SM3 signer (the Chinese national standard) was added without changing the executor, and reproduces the standard test vector.

7.2 Why this is a strength

- **Protects against harvest now, forge later.** A signed payment record and its proof pack are meant to be checked for years. Signatures made today with a post-quantum algorithm stay trustworthy if large quantum computers arrive, which Ed25519 alone would not.
- **Belt and braces.** Both signatures must verify, so a break in either algorithm alone does not let an attacker forge a payment record. The newer algorithm cannot weaken the proven one.
- **Standard algorithms, no home-made cryptography.** ML-DSA-65 is the NIST FIPS 204 standard through a maintained library; Ed25519 is used the same way. The key exchange is the hybrid ML-KEM group built into current browsers and TLS libraries.
- **Security compliance, unauthorized operations.** An attacker who strips or forges either signature cannot get a payment executed (Section 7.3: ML-DSA-65 signature removed, refused).

- **Fits the track.** A verified payment history is only useful to a lender if it can still be checked later and cannot be re-signed; long-lived records are exactly where post-quantum signatures matter first.
- **Replaceable.** Because algorithms are a list, a future scheme can be added or one retired without redesigning the executor or the proof format.

7.3 Measured in this build (offline, seeded demo keys)

Check	Result
Signature sizes: Ed25519 / ML-DSA-65	64 bytes / 3,309 bytes
Public key sizes: Ed25519 / ML-DSA-65	32 bytes / 1,952 bytes
Honest payment message, both signatures	**verifies**
Same signatures, message altered by one character	**refused**
Valid Ed25519 signature with the ML-DSA-65 signature removed	**refused**
Executor tests: tampered, replayed, expired and forged signed payments	**refused**, in the offline suite
Post-quantum TLS handshake, local test (Caddy limited to the hybrid group): hybrid client / classical-only client	**X25519MLKEM768 negotiated** / **refused**
Deployed VM (`oasis.koreacentral.cloudapp.azure.com`): Chrome DevTools, Security tab	**X25519MLKEM768**
Deployed VM: classical client (Windows curl 8.21.0, Schannel, `GET /api/health`)	**connects, HTTP 200**

The signature checks were run for this report on the project's own signer. Local handshake evidence is the saved recorded run: Caddy 2.11.7 with an OpenSSL 3.5.9 client, a Go reference server, and Chrome 155. The deployed site offers the hybrid group but does not refuse classical clients, so it does not enforce post-quantum key exchange.

8. Known-Risk List

Severity is the authors' judgement of the harm if the risk were exploited in a real deployment, not a score from a standard. Status says what has been done in this build. Findings from earlier adversarial reviews that were fixed (races on approval, non-finite amounts, cross-origin posts, duplicate payment, proof-pack forgery and others) are in Appendix A.

Signed conversions, standing instructions and rate targets (C01, C02). None can be released without the student's key (a wrong key gives 403, a replayed nonce is refused) and a bill that rises above its signed cap is held. Residual: `POST /api/rate-target` still creates a bounded Tier-1 target without a signature.

#	Severity	Risk	Status	Mitigation or next step
1	**HIGH**	**Self-written evidence and small live samples; no external audit** Tests and attack sets were largely written by the team. Three outside AI sets exposed failures that were then fixed, so final scores are not out-of-sample. Live checks used one model and our own texts (128 poisoned and 40 genuine invoices, three outside sets; some sets were not run live), are small samples and are not a robustness claim. Nova calls are not in the Oasis audit chain: saved rows are the record, not a provider-side log. Stress and fuzz runs are white-box, written by the team. No human penetration test or certification.	Open	Independent audit, a human red team and larger live runs. The deterministic layers carry the guarantee regardless of model results.
2	**HIGH**	**Everything is simulated** Rails, rates, fees, the payee registry and the humans in the benchmark are mocks. A compromised or wrong registry would defeat verification.	Accepted for the sandbox	Real rails, a licensed partner and a governed registry (Section 9).
3	**LOW**	**Chat labeller can accept a payment label on a manipulation message** Final live re-run, 50 messages: 1 of the original 25 was accepted (a held draft to the registry payee, signature required); 0 of 25 fresh traps were accepted; CNY 0 moved.	Mitigated; bounded	A payment label only creates a draft that needs the student's device-key signature, to the registry payee. One run, one model, our own messages.
4	**LOW**	**Chat can add a sandbox foreign-currency bill** A message such as "pay a USD application fee of 100 dollars" adds a USD or EUR bill to one of two fixed MOCK universities and drafts it. The payee and account come from that table, the amount is capped, the addition is audited and the draft still needs the device-key signature; the amount is typed by the student.	Accepted for the sandbox	With real payees a bill must come from the payee or the registry, not from chat.

5	**LOW**	**Chat tasks tested only by our own tests; scam check is a heuristic** The chat tasks have 38 team-written tests, no outside-written set; the model was run live once on messages the router could not place (74 calls, our own messages). The scam check uses deterministic rules and the registry, calls no model, and "no warning signs" is not a guarantee; it makes no draft and moves CNY 0.	Open	Run an outside-written set against these tasks and report it; keep the verdict wording as it is.
6	**LOW**	**Router misses some unseen wording** Unseen wording can still get a fixed answer, a hedge or a question about which bill is meant; no draft, CNY 0 moved. Figures in Section 6.3.	Mitigated (offline)	Concept lexicon, context, scam lane and FAQ added; 58.9% on words withheld from the lexicon, so vocabulary outside it remains the weakest area.
7	**MEDIUM**	**Risk scorers weaker out of sample** The heuristic was tuned on the benchmark, and neither scorer can see poisoned tool output (0 of 6). The trained model is modest (AUC 0.80 against 0.75).	Accepted; escalate-only	Executor and intent binding carry the guarantee. Sequence flags raised split-payment scores to 0.636.
8	**MEDIUM**	**Authentication is demo-grade** Per-role passcodes, no per-person accounts, no MFA. Device-key enrolment is trust on first use: whoever holds a role's passcode can register a new key, which retires the old one. The login throttle is per address, so it can lock out the real user behind it: several judges on one network can share the limit of 5 failed logins a minute in judge mode; it resets after a minute. A stolen role passcode can register a new device key; judging passcodes are random and each login gets its own sandbox.	Open	Per-user accounts, out-of-band device enrolment or WebAuthn. An optional passkey second factor exists, off by default and untested on a hardware key.
9	**MEDIUM**	**Keys held as local files** The data key and trust signing key are plaintext files protected by OS permissions unless a passphrase is set; on Windows file mode does not restrict access. Anyone who can read them can decrypt the database.	Open	A key vault or hardware module. The judge start scripts set a random passphrase.
10	**LOW**	**Model reading and output failures** Final live image run, 33 MOCK images: 30 accepted (payee and amount correct in all 30, 0 invented payees), 3 held, and 3 accepted images had an account digit dropped. The earlier 2-of-6 failures came before the quality gate and runaway guard. The provider's filter blocked one answer, and 2 of 168 risk answers were malformed JSON.	Mitigated	Quality gate, two-pass agreement and runaway guard hold bad readings; the registry-only payment rule and the student confirming fields limit the harm. One run, one model, synthetic images.

11	**LOW**	**First part of a split payment executes** Splitting is only visible from the second payment, so with three parts of CNY 3,300 against a CNY 3,498 co-approval threshold the first is paid to the student's own registry account and the other two are held (rule R06, no ledger entry). The execution evidence shows this as partly held.	Accepted by design	Loss is capped at one below-threshold amount to a registry payee; a test pins the behaviour.
12	**LOW**	**Sandbox simplifications** Converted funds stay in the student's own account if the executor refuses a payment. Draft expiry uses a simulated clock. Signed intents carry floats (ledger balances use exact fen arithmetic). One fixed USD/INR of 88.0 is used in some checks. Demo keys are seeded and public, so a pack forged with them would verify while the demo runs.	Accepted for the sandbox	Wall clock, decimal money, a rate service and vault keys in production. The fingerprint endpoint reports demo mode.
13	**LOW**	**Post-quantum, anchoring and TLS limits** The TLS certificate is classical: only the key exchange is post-quantum, so an attacker who can break classical signatures could still impersonate the server. TLS is provided by the proxy; the live-handshake test is skipped by default and the evidence is a recorded manual run (Caddy with OpenSSL 3.5, Chrome 155). The deployed VM's handshake is recorded (Section 7.3): Chrome DevTools, Security tab, shows X25519MLKEM768, and a classical Windows curl client still connects. The approver's own signature is Ed25519 only, protected because the draft is bound inside the hybrid-signed intent. ML-DSA comes from a general-purpose library (the hybrid rule limits a flaw; none found). SM2 uses a pure-Python library that is not constant-time and not audited. The anchor is a local simulation by default; FISCO BCOS is a four-node test chain on one host. No independent cryptographic review has been done.	Recorded (handshake); otherwise disclosed	A post-quantum certificate when available, a multi-host chain and an independent cryptographic review.
14	**LOW**	**Unvalidated inputs and channels** Regulatory figures are not confirmed by a bank or counsel, and sanctions screening is one public list. Chinese text is machine-translated; the Tamil and Hindi text was checked by the team (the interface is English and Chinese; the parent view is English, Tamil, Hindi and Chinese). User research was informal conversations with 10 people we know (6 international students and interns, 4 parents): a small convenience sample, not a survey; no finance office was interviewed (Technical Documentation, Section 1.1). Telegram and IMAP were tested only against fake servers.	Disclosed	Confirm figures with a dealer bank and counsel, native review, user research and real-account tests.

15	**LOW**	**Payee account number is masked in chat, not everywhere** Chat replies show a payee account masked (like ****1234); the signing panel and the state view show the full registry account number so the signer can check it. Anyone logged in as that role can read it.	Accepted by design	Role-scoped views; the registry account is not secret to the payer. Reword any claim as masked in chat, full number on the signing panel.

9. Out of Scope and Path to Production

9.1 Out of scope

- Compromise of the host machine or of the signing keys.
- Compromise of the registry itself.
- Real banking integration.
- Production key management.
- Denial of service and load.
- The correctness of regulatory figures beyond the stated research.

9.2 Path to production

Gap	What is needed
Licensing and real rails	A licensed payment partner and real bank integrations. Oasis is a sandbox; it is not a licensed financial service and gives no financial advice.
Independent assurance	External penetration test and code audit, then a human red team of students, parents and fraud investigators.
Identity and keys	Per-user accounts, MFA or passkeys, out-of-band device enrolment, and keys held in a vault or hardware module.
Data and compliance	Counsel-confirmed corridor rules, a governed payee registry, privacy review for personal data, and decimal money end to end.
Operations	Load testing, a second host, rotated and scoped credentials, monitoring and an incident process.

Appendix A. Hardening History

Dated hardening rounds, replacing the earlier review log. Each change has a regression test.

Round	Change
Round 1	**Role guards and signed one-hour sessions** Least privilege per role; 401 and 403 behaviour; failed-login limit.
Round 2	**Device-key approvals** Ed25519 over the exact draft hash, keys kept in the approver's browser.
Round 3	**Encryption at rest** AES-256-GCM per payload column with row-bound data; hash chain re-verified after decrypt.
Round 4	**Short-lived tool tokens** 30-second, single-use token bound to the intent; the baseline keeps a static credential on purpose.
Round 5	**Judge review fixes** Serialised requests and atomic audit appends (approval race); non-finite and fractional-fen amounts refused; strict request models; Origin check and body cap; risk hold no longer offers an approval that cannot release it; expired drafts retired with 410; proof verification never raises; duplicate-payment rule R17; text caps; clear key-file errors.
Round 6	**Proof-pack forgery found by external review** Verification now pins the server's key fingerprint and checks the anchor and chain.
Round 7	**Security headers, passkey second factor, inbound channel rules, sanctions screening, zero-knowledge threshold proofs** Content-Security-Policy and related headers; optional WebAuthn; email and chat provenance as evidence only; OFAC list snapshot raising review.
Round 8	**Chat tasks** Deterministic intent router with security categories first; payments built from the registry, never from text; audited refusals and a redaction filter; corrections void the old draft; over-the-bill refusal.
Round 9	**Live evidence rounds** Large live invoice, chat and outside-set runs with a token cap; vision guard; tolerant JSON parsing; lifetime token budget.
Round 10	**Sequence flags and FlightPath** Payment-burst, third-payment and large-amount flags raise risk (escalate only); recovery advice never resends; why-cards state uncertainty; rewrite guard.

Appendix B. How to Reproduce

All commands run offline and make no model call. Run them from the repository root.

Purpose	Command
Offline test suite (expect 2731 passed, 2 skipped)	`OASIS_DB=:memory: OASIS_LLM=offline PYTHONPATH=. python -m pytest -q`
Role matrix only	`OASIS_LLM=offline PYTHONPATH=. python -m pytest -q tests/test_role_matrix.py`
Offline benchmark	`OASIS_LLM=offline PYTHONPATH=. python -m eval.runner --llm offline`
Rebuild this report	`PYTHONPATH=. python -m eval.build_security_pdf`

Live-model results are saved report rows; reproducing them needs the owner's approval and a capped key.

Appendix C. Glossary

Term	Meaning
Audit chain	A log in which each entry contains the hash of the previous one, so any later change is detectable.
Canary	A decoy credential or account no honest request would touch; using it signals an attack.
Device-key approval	A signature made with the approver's registered device key over the exact payment draft.
Executor	The only component that moves money; it enforces the signed intent exactly.
Intent	A signed record of one exact payment: payee, account, amount, currency, route, nonce and expiry.
MOCK	Simulated data. Not real.
Nonce	A value that may be used once; reuse indicates a replay.
Registry	The list of verified payees and their accounts. Money goes only to a registry account.
Validator	Deterministic code that checks everything the model proposes before it is used.
Tier	Autonomy level: 1 the agent acts alone within bounds, 2 a human approves, 3 never (freeze).